



COTEJO

Programa de auditoría con verificación automatizada de controles

Sistema auditado: **Rastro**

Sergio Montoya · Nicolás Torres · Oscar Rincón
Auditoría de Sistemas (ISD39) · Grupo 30112

1 · Portada · Nicolás · ≈ 20 s

Nicolás: Buenos días, profesor. Somos Sergio Montoya, Nicolás Torres y Oscar Rincón, del grupo 30112. Vamos a sustentar Cotejo, un programa de auditoría que verifica de forma automatizada los controles de un sistema desplegado. El sistema auditado es Rastro, y seguimos los siete bloques que usted pidió.

INDICACIÓN Diez segundos. Mirar al jurado, no a la pantalla.

BLOQUE 1

Presentación del sistema

- 2 Contexto y sistema auditado
- 3 El problema que motivó la auditoría



Cotejo

Bloque 1

Bloque 1 · Presentación del sistema

Portadilla: se pasa sin detenerse.

Contexto y sistema auditado

Organización. Empresa de mensajería urbana de pequeño tamaño en Bogotá, sobre infraestructura compartida entre varias empresas.

Sistema auditado. Rastro, sistema de trazabilidad de envíos desplegado en AWS, cuenta `484948252891` , región `us-east-1` . Ocho funciones, tres tablas, almacén cifrado y registro de actividad.

Quién lo construyó. El mismo equipo, en la asignatura de Cloud Computing.



2 · Contexto y sistema auditado · Nicolás · ≈ 35 s

Nicolás: El caso es una empresa pequeña de mensajería urbana en Bogotá que comparte infraestructura con otras empresas. El sistema auditado es Rastro: registra el ciclo de vida de cada envío y está desplegado en AWS, con ocho funciones, tres tablas, un almacén cifrado y registro de actividad. Y lo decimos de entrada: Rastro lo construimos nosotros, en Cloud Computing. Auditamos nuestro propio sistema, y más adelante explicamos cómo tratamos esa falta de independencia.

INDICACIÓN Decirlo primero quita la objeción antes de que el jurado la haga.

El problema que motivó la auditoría

Un control declarado no es un control verificado.

Lo comprobamos antes de construir nada:

La configuración dice

Autoriza a cualquier principal

El sistema hace

Rechaza **toda** invocación

Un auditor que solo lee configuraciones habría reportado un hallazgo falso.



3 · El problema que motivó la auditoría · Nicolás · ≈ 35 s

Nicolás: La idea que motivó el proyecto es esta: un control declarado no es un control verificado. Lo comprobamos antes de construir nada. Configuramos a propósito una función con una política que autoriza a cualquier principal; quien lea esa configuración concluye que está abierta. Pero al invocarla, el sistema rechaza toda invocación. Un auditor que solo leyera configuraciones habría reportado un hallazgo falso. Por eso Cotejo no solo lee: usa el sistema.

SI PREGUNTAN Es evidencia recuperable: el comando y la petición se repiten y dan el mismo resultado. Está descrita en el apartado 3.1 del documento.

BLOQUE 2

Planificación

- 4 Objetivos
- 5 Alcance y exclusiones
- 6 Responsables, recursos y cronograma
- 7 Actividades realizadas



Objetivos

General. Verificar de forma automatizada y reproducible los controles de un sistema desplegado, con papeles de trabajo trazables a un marco de referencia.

Específicos

1. Definir el universo auditable y la matriz de controles
2. Diseñar el programa de pruebas con su criterio de aceptación
3. Construir el ejecutor y el almacén de papeles de trabajo
4. Ejecutar, evaluar desviaciones y emitir el informe

Los cuatro cumplidos.



4 · Objetivos · Nicolás · ≈ 30 s

Nicolás: El objetivo general fue verificar de forma automatizada y reproducible los controles de un sistema desplegado, con papeles de trabajo trazables a un marco de referencia. Los cuatro objetivos específicos siguen el orden de una auditoría: definir qué se audita y contra qué, diseñar las pruebas con su criterio, construir el ejecutor y ejecutar para emitir el informe. Los cuatro se cumplieron.

INDICACIÓN No leer la lista: resumirla en una frase.

Alcance y exclusiones

Dentro	Fuera
Diez controles trazados a marcos externos	Auditoría del proceso de desarrollo
Configuración de la infraestructura	Revisión de código fuente
Comportamiento de la aplicación	Pruebas de intrusión
Integridad de la bitácora	Vigilancia continua desatendida
Secretos en el repositorio	Sistemas distintos de Rastro

Condicionado y no logrado: retención inmutable del almacén de papeles. El entorno no la permitió y se declara.



5 · Alcance y exclusiones · Nicolás · ≈ 35 s

Nicolás: El alcance son diez controles trazados a marcos externos, que cubren la configuración de la infraestructura, el comportamiento de la aplicación, la integridad de la bitácora y los secretos del repositorio. Quedaron fuera la auditoría del proceso de desarrollo, la revisión de código, las pruebas de intrusión, la vigilancia continua y cualquier otro sistema. Y declaramos lo que no logramos: la retención inmutable del almacén de papeles, que el entorno no permitió.

SI PREGUNTAN Diez controles producen once resultados porque el de secretos se parte en tres: árbol actual, historial y vigencia.

Responsables, recursos y cronograma

Fase	Semanas	Responsable	Estado
Planeación y catálogo	1–3	Oscar Rincón	Cerrada
Diseño del programa	4–5	Sergio Montoya	Cerrada
Construcción	6–9	Nicolás Torres	Cerrada
Ejecución y comunicación	10–12	Oscar Rincón	En curso

Regla de independencia interna: quien construyó un componente de Rastro no ejecuta ni evalúa las pruebas de ese componente.

Recursos: la cuenta del laboratorio, sin costo adicional. El programa reutiliza los recursos ya desplegados.



6 · Responsables, recursos y cronograma · Nicolás · ≈ 30 s

Nicolás: Trabajamos doce semanas en cuatro fases: Oscar hizo la planeación y el catálogo, Sergio diseñó el programa, yo lo construí, y Oscar ejecuta y comunica, que es la fase que cierra ahora. Lo importante es la regla de independencia interna: quien construyó un componente de Rastro no ejecuta ni evalúa las pruebas de ese componente. Y no hubo costo adicional: el programa reutiliza la cuenta y los recursos ya desplegados.

Actividades realizadas

- Prueba preliminar que evidenció el problema
- Catálogo derivado de COBIT, ITAF, ISO 27001, CIS y OWASP
- Programa de unas 3.400 líneas con tres familias de prueba
- Almacén de papeles de trabajo y generador de informe
- Interfaz de consulta restringida al rol auditor
- **Dos ejecuciones** contra el sistema desplegado
- Ampliación del catálogo tras un incidente real



7 · Actividades realizadas · Nicolás · ≈ 30 s

Nicolás: En resumen: la prueba preliminar que acabamos de ver, un catálogo derivado de COBIT, ITAF, ISO 27001, CIS y OWASP, un programa de unas 3.400 líneas con tres familias de prueba, el almacén de papeles con su informe, una interfaz solo para el rol auditor, dos ejecuciones contra el sistema desplegado y una ampliación del catálogo tras un incidente real, que veremos en los hallazgos.

INDICACIÓN Es inventario: pasar rápido.

BLOQUE 3

Metodología

- 8 Marco y secuencia
- 9 Técnicas empleadas y por qué
- 10 Tres conclusiones, no dos



Cotejo

Bloque 3

Bloque 3 · Metodología

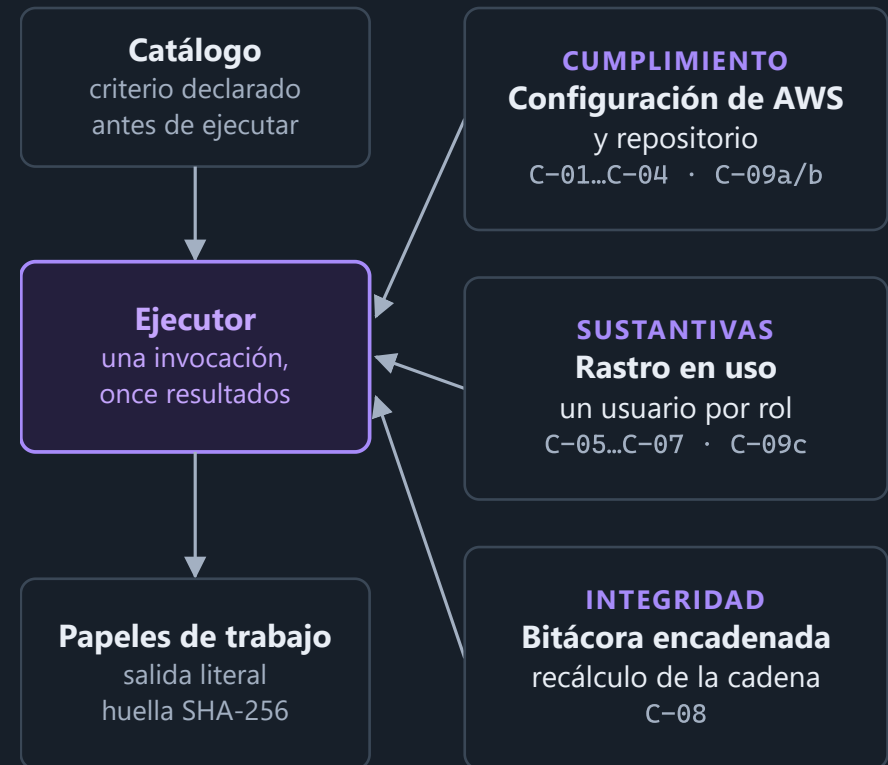
Portadilla: se pasa sin detenerse.

Marco y secuencia

Secuencia de un trabajo de aseguramiento conforme a **ITAF** (ISACA, 2020):

planeación → diseño del programa → ejecución y evidencia → evaluación y comunicación

Regla que gobierna todo: el criterio de cada prueba se declara **antes** de ejecutarla. El catálogo lleva fecha anterior a la primera ejecución, para que el criterio no pueda acomodarse al resultado.



8 · Marco y secuencia · Nicolás · ≈ 35 s

Nicolás: Seguimos la secuencia de un trabajo de aseguramiento según ITAF, de ISACA: planeación, diseño del programa, ejecución con evidencia, y evaluación y comunicación. Una regla gobernó todo: el criterio de cada prueba se declara antes de ejecutarla, y el catálogo tiene fecha anterior a la primera ejecución, para que el criterio no se acomode al resultado. En la figura, el ejecutor toma el catálogo, obtiene evidencia de tres fuentes, una por familia de prueba, y escribe los papeles de trabajo.

SI PREGUNTAN ¿Por qué ITAF? Es el marco de prácticas profesionales de auditoría de sistemas de ISACA, y define qué es evidencia suficiente y confiable.

Técnicas empleadas y por qué

Técnica	Para qué	Por qué esa
Revisión documental de marcos	Derivar el catálogo	Que el alcance sea una decisión y no un olvido
Inspección de configuración	Pruebas de cumplimiento	Es el estado declarado del recurso
Reejecución de operaciones	Pruebas sustantivas	La configuración puede contradecir el comportamiento
Recálculo criptográfico	Prueba de integridad	Único modo de comprobar una cadena de hashes
Análisis del repositorio	Control de secretos	El historial también es el repositorio

No usamos entrevistas ni listas de verificación. El objeto es un sistema desplegado, no un proceso humano: preguntarle al responsable habría producido exactamente la respuesta que el proyecto busca evitar.



9 · Técnicas empleadas y por qué · Nicolás · ≈ 40 s

Nicolás: Cada técnica tiene su porqué. La revisión documental de los marcos nos dio el catálogo. La inspección de configuración sirve para las pruebas de cumplimiento. La reejecución de operaciones, para las sustantivas, porque la configuración puede contradecir el comportamiento. El recálculo criptográfico es la única forma de comprobar la cadena de la bitácora. Y el análisis del repositorio cubre los secretos. No usamos entrevistas ni listas de verificación: el objeto es un sistema, y preguntarle al responsable nos daría justo la respuesta que queremos evitar. Oscar explica cómo se clasifica cada resultado.

INDICACIÓN La última frase justifica las técnicas por exclusión, que es lo que pide la rúbrica.

Tres conclusiones, no dos

BIEN	Se probó y cumplió el criterio escrito de antemano
MAL	Se probó y no cumplió. Se convierte en hallazgo
SIN REVISAR	No se pudo probar. Pendiente, no aprobado

Mezclar la tercera con las otras dos informa más cobertura de la que hubo.



Oscar: Gracias, Nicolás. Cada prueba termina en una de tres conclusiones, no dos. BIEN: se probó y cumplió el criterio escrito de antemano. MAL: se probó y no cumplió, y se convierte en hallazgo. SIN REVISAR: no se pudo probar; queda pendiente, no aprobado. Si mezcláramos la tercera con las otras, el informe diría que revisamos más de lo que revisamos. Más adelante reconocemos que una vez la aplicamos mal.

BLOQUE 4

Riesgos y controles

- 11 Activos identificados
- 12 Amenazas, probabilidad e impacto
- 13 Controles existentes y faltantes
- 14 Roles y permisos del sistema auditado
- 15 Matriz de permisos · envíos y operación
- 16 Matriz de permisos · administración y auditoría
- 17 Reglas de los roles que no se pueden configurar
- 18 Permisos fuera de la aplicación



Activos identificados

Activo	Por qué importa
Datos de envíos y destinatarios	Información personal de terceros
Evidencias de entrega	Prueba de la cadena de custodia
Bitácora de auditoría	Sostiene el no repudio del sistema
Llave de cifrado	Compromete todas las evidencias
Secreto de firma de sesiones	Permite suplantar cualquier rol
Papeles de trabajo	Enumeran las debilidades del sistema



11 · Activos identificados · Oscar · ≈ 30 s

Oscar: Identificamos seis activos. Los datos de envíos y destinatarios, información personal de terceros; las evidencias de entrega, que prueban la cadena de custodia; la bitácora, que sostiene el no repudio; y la llave de cifrado y el secreto de firma, porque comprometerlos compromete todo lo demás. Y uno que suele olvidarse: los papeles de trabajo, porque enumeran las debilidades del sistema. Por eso no están en el repositorio público.

SI PREGUNTAN Los papeles se entregan directamente al evaluador; publicarlos sería repetir el error del incidente.

Amenazas, probabilidad e impacto

Amenaza	Prob.	Impacto	Control
Acceso a datos de otra organización	Media	Muy alto	Clave de partición por organización · C-06
Alteración del histórico	Baja	Muy alto	Bitácora encadenada · C-08
Operación por rol no autorizado	Media	Alto	Autorización en capa común · C-05
Exposición de secretos	Media	Muy alto	C-09a, C-09b, C-09c
Evidencias legibles por terceros	Baja	Alto	Cifrado y bloqueo público · C-02, C-03
Enumeración de envíos	Media	Medio	Identificadores aleatorios



12 · Amenazas, probabilidad e impacto · Oscar · ≈ 30 s

Oscar: Para cada amenaza valoramos probabilidad e impacto y le asignamos un control del catálogo. Las de impacto muy alto son tres: el acceso a datos de otra organización, que controla C-06; la alteración del histórico, que controla C-08; y la exposición de secretos, que cubren los tres controles C-09. Esta última va resaltada porque se materializó durante el proyecto; la desarrollamos en los hallazgos.

Controles existentes y faltantes

Existen y funcionan. Registro de actividad con validación de integridad, cifrado con llave propia y rotación, bloqueo de acceso público, versionado, autorización por rol, aislamiento entre organizaciones, máquina de estados y bitácora encadenada.

Faltan, y el entorno impide construirlos.

- Rol de ejecución por función → incumple mínimo privilegio
- Credenciales de solo lectura para el auditor
- Ancla de integridad fuera de la cuenta



13 · Controles existentes y faltantes · Oscar · ≈ 35 s

Oscar: Los controles existentes funcionan: registro de actividad con validación de integridad, cifrado con llave propia y rotación, bloqueo de acceso público, versionado, autorización por rol, aislamiento entre organizaciones, máquina de estados y bitácora encadenada. Y faltan tres que el entorno impide construir: un rol de ejecución por función, credenciales de solo lectura para el auditor y un ancla de integridad fuera de la cuenta. No son olvidos: se declaran en cada informe.

Roles y permisos del sistema auditado

Rol	Puede	No puede
Administrador	Todo: envíos, catálogos, cuentas y roles	Leer la bitácora
Coordinador	Despachar, reanudar incidencias, editar catálogos	Administrar cuentas; leer bitácora
Despachador	Crear y asignar envíos, registrar eventos	Reanudar incidencias; editar catálogos
Conductor	Ver sus envíos, marcar avance, cargar evidencia	Crear o asignar envíos
Auditor	Consultar y leer la bitácora	Cualquier operación de escritura

Ningún rol combina escritura con lectura de la bitácora, y ninguna cuenta puede sumar dos roles que juntos lo hagan. No es configurable.



14 · Roles y permisos del sistema auditado · Oscar · ≈ 35 s

Oscar: Rastro tiene cinco roles de fábrica. El administrador puede todo, menos leer la bitácora. El coordinador despacha, reanuda incidencias y mantiene catálogos. El despachador registra y asigna envíos. El conductor trabaja solo sobre sus envíos. Y el auditor consulta y lee la bitácora, sin escribir nada. Para la auditoría, lo que importa es la segregación de funciones: ningún rol combina operar con leer la bitácora, y ninguna cuenta puede sumar dos roles que juntos lo hagan.

Matriz de permisos · envíos y operación

Operación	Administrador	Coordinador	Despachador	Conductor	Auditor
Registrar envíos, uno a uno o en lote	✓	✓	✓	—	—
Asignar mensajero y ver toda la operación	✓	✓	✓	—	—
Ver el listado de envíos	✓	✓	✓	Solo suyos	—
Abrir un envío y su histórico	✓	✓	✓	✓	✓
Marcar el avance del envío	✓	✓	✓	Solo suyos	—
Autorizar un envío detenido por incidencia	✓	✓	—	—	—
Adjuntar la prueba de entrega	✓	—	—	Solo suyos	—
Consultar las evidencias cargadas	✓	✓	✓	—	✓

Quien detiene no es quien reanuda: el conductor reporta la incidencia; autorizar la continuación corresponde a otro rol.



15 · Matriz de permisos · envíos y operación · Oscar · ≈ 30 s

Oscar: Esta matriz es el criterio con que juzgamos la autorización, y la tomamos del código del sistema auditado, no de lo que recordábamos haber programado. En la operación, el conductor solo lista, marca avance y adjunta evidencia de sus propios envíos. Y quien detiene un envío no es quien lo reanuda: el conductor reporta la incidencia, pero autorizar la continuación le corresponde al coordinador o al administrador.

Matriz de permisos · administración y auditoría

Operación	Administrador	Coordinador	Despachador	Conductor	Auditor
Ver las cuentas de la empresa	✓	✓	—	—	✓
Crear cuentas	✓	—	—	—	—
Cambiar rol, datos o estado de una cuenta	✓	—	—	—	—
Ver los roles y sus permisos	✓	—	—	—	✓
Crear roles y cambiar sus permisos	✓	—	—	—	—
Ver los mensajeros disponibles	✓	✓	✓	—	—
Ver tiendas, clientes y transportistas	✓	✓	✓	✓	✓
Modificar tiendas, clientes y transportistas	✓	✓	—	—	—
Ver el tablero de indicadores	✓	✓	✓	✓	✓
Leer la bitácora	—	—	—	—	✓
Verificar la integridad de la cadena	—	—	—	—	✓

De 19 operaciones: Administrador 17 · Coordinador 12 · Despachador 9 · Conductor 6 · Auditor 8



16 · Matriz de permisos · administración y auditoría · Oscar · ≈ 25 s

Oscar: En administración, solo el administrador crea cuentas, cambia roles y define permisos; el auditor puede verlos, pero no modificarlos. Las dos últimas filas son la segregación de funciones: leer la bitácora y verificar su integridad son exclusivas del auditor. Por eso el administrador tiene 17 de las 19 operaciones.

Reglas de los roles que no se pueden configurar

Regla	Qué evita
El administrador conserva siempre sus 17 operaciones y su rol no se edita	Que una edición deje a la empresa sin nadie que pueda corregirla
Ningún rol ni cuenta combina escritura con lectura de la bitácora	Que quien opera revise su propio rastro
Nadie concede un permiso que no tiene	La autopromoción: el intento queda en la bitácora como escalada de privilegios
Sin permiso de asignar, solo se actúa sobre los envíos propios	Que un mensajero marque avance o cargue evidencia en envíos ajenos

C-05 comprueba una celda de la matriz: un conductor que intenta crear un envío recibe 403 y el intento queda registrado. El resto lo cubren las pruebas del propio Rastro.



17 · Reglas de los roles que no se pueden configurar · Oscar · ≈ 35 s

Oscar: Cuatro reglas no se pueden configurar: el rol de administrador no se edita, ningún rol ni cuenta combina operar con auditar, nadie concede un permiso que no tiene, y sin permiso de asignar solo se actúa sobre envíos propios. Y seamos precisos sobre lo que auditamos: C-05 comprueba una celda de esta matriz, un conductor que intenta crear un envío, que recibe 403 y queda registrado. El resto lo cubren las pruebas del propio Rastro, que no son pruebas de auditoría.

INDICACIÓN Decirlo así evita que parezca que la auditoría recorrió toda la matriz.

SI PREGUNTAN Las pruebas de cada regla están en `tests/e2e/test_rol.py` y `tests/unit/test_autorizacion_y_claves.py`, pero son de quien construyó el sistema.

Permisos fuera de la aplicación

Identidad	Con qué permisos opera	Resultado
Las ocho funciones de Rastro	Un rol compartido del laboratorio, con permisos amplios	H-PERM-01 · severidad alta
El programa de auditoría	El mismo rol: puede escribir sobre lo que audita	H-PERM-02 · severidad media
Usuarios de prueba de Cotejo	Uno por rol y organización; credenciales por variable de entorno, sin versionar	Hacen posibles las pruebas sustantivas
Interfaz de Cotejo	Solo el rol auditor; cualquier otro recibe rechazo	Los papeles enumeran debilidades

Dentro de la aplicación la matriz se cumple; fuera de ella, el entorno impide aplicar mínimo privilegio.



18 · Permisos fuera de la aplicación · Oscar · ≈ 35 s

Oscar: La matriz se cumple dentro de la aplicación, pero no cubre la infraestructura. Las ocho funciones comparten un rol amplio del laboratorio: es el hallazgo permanente H-PERM-01, de severidad alta. El propio programa de auditoría corre con ese mismo rol, con permisos de escritura sobre lo que audita: H-PERM-02, severidad media. Los usuarios de prueba usan credenciales que no se versionan, y la interfaz de Cotejo solo admite al rol auditor. Sergio sigue con la normativa.

BLOQUE 5

Normativas

19 Marcos aplicados

20 Cumplimientos e incumplimientos



Cotejo

Bloque 5

Bloque 5 · Normativas

Portadilla: se pasa sin detenerse.

Marcos aplicados

Marco	Qué aporta	Control
COBIT 2019, DSS05 y DSS06	Seguridad y control de procesos	C-05, C-06, C-07
ITAF	Evidencia suficiente y confiable	Estructura del informe
ISO/IEC 27001:2022	Criptografía, copias, autenticación	C-02, C-04, C-09
CIS AWS Benchmark	Configuración segura de la cuenta	C-01, C-03
OWASP Top 10:2021 A01	Control de acceso deficiente	C-05, C-06
NIST SP 800-92 y 800-57	Registros y compromiso de llaves	C-01, C-09c

El catálogo se deriva de los marcos, no de nuestra intuición. Así, un control ausente es una decisión de alcance y no un olvido.



19 · Marcos aplicados · Sergio · ≈ 40 s

Sergio: Gracias, Oscar. Cada control del catálogo sale de un marco: COBIT para la autorización, el aislamiento y las transiciones; ITAF para el informe y la calidad de la evidencia; ISO 27001 para cifrado, copias y secretos; CIS para la configuración de la cuenta; OWASP para el control de acceso; y NIST para los registros y las llaves. El argumento es este: el catálogo se deriva de los marcos, no de nuestra intuición, así que un control ausente es una decisión de alcance y no un olvido.

INDICACIÓN No leer la tabla: nombrar los marcos y llegar a la frase final.

Cumplimientos e incumplimientos

11

resultados

10

conformes

1

desviado

0

sin ejecutar

Cumple. Registro con validación de integridad, cifrado con rotación, sin acceso público, versionado, autorización por rol, aislamiento, transiciones válidas, bitácora detectable, árbol del repositorio limpio y secretos hallados sin vigencia.

Incumple. Un secreto permanece en el historial de commits.



20 · Cumplimientos e incumplimientos · Sergio · ≈ 30 s

Sergio: En la ejecución de referencia, del 26 de septiembre, obtuvimos once resultados: diez conformes, uno desviado y ninguno sin ejecutar. Cumplen el registro de actividad, el cifrado, el bloqueo público, el versionado, la autorización, el aislamiento, las transiciones y la bitácora; el árbol del repositorio está limpio y los secretos encontrados ya no sirven. Lo que incumple es que un secreto sigue en el historial de commits.

INDICACIÓN No pasar rápido por el incumplimiento: es la transición a los hallazgos.

BLOQUE 6

Hallazgos y evidencias

- 21 H-01 · Secreto en el historial
- 22 Los dos hallazgos permanentes
- 23 También nos auditamos a nosotros
- 24 Trazabilidad de la evidencia



Cotejo

Bloque 6

Bloque 6 · Hallazgos y evidencias

Portadilla: se pasa sin detenerse.

H-01 · Secreto en el historial

Condición	Un secreto de firma permanece en el historial, fuera del árbol actual
Criterio	ISO/IEC 27001 A.5.17 y A.8.4 · CWE-798
Causa	Se versionó en un commit; retirar el archivo después no lo saca del historial
Riesgo	Visible para quien consulte el historial. Severidad media: el secreto ya fue invalidado
Evidencia	Papel C-09b.json · huella f56b8e66...

Recomendación. Reescribir el historial. No sustituye a la rotación, que ya se ejecutó.



Sergio: El primer hallazgo sigue el formato que pide la rúbrica. Condición: un secreto de firma sigue en el historial del repositorio, aunque ya no está en el árbol actual. Criterio: ISO 27001 sobre información de autenticación y acceso al código, y CWE-798. Causa: se versionó en un commit, y borrar el archivo después no lo saca del historial. Riesgo: medio, porque el secreto ya está invalidado. Evidencia: el papel de trabajo de C-09b con su huella. Recomendación: reescribir el historial, que no reemplaza la rotación ya hecha.

Los dos hallazgos permanentes

H-PERM-01 · Mínimo privilegio — severidad alta

Las ocho funciones comparten un rol amplio. El laboratorio no permite crear roles. Se declara en cada informe en lugar de omitirse.

H-PERM-02 · Privilegios del auditor — severidad media

El programa corre con permisos de escritura sobre lo que audita. Un auditor con permisos de escritura no es un auditor.

Ambos **fuera del alcance automatizado**: una prueba que siempre da el mismo resultado no aporta información.



22 · Los dos hallazgos permanentes · Sergio · ≈ 35 s

Sergio: Los otros dos hallazgos son permanentes. Mínimo privilegio, de severidad alta: las ocho funciones comparten un rol amplio porque el laboratorio no permite crear roles. Y privilegios del auditor, de severidad media: el programa corre con permisos de escritura sobre lo que audita, y un auditor con permisos de escritura no es un auditor. No los automatizamos a propósito: una prueba que siempre da el mismo resultado no aporta información. Por eso se declaran en cada informe.

También nos auditamos a nosotros

El incidente. Publicamos un secreto de firma en el repositorio durante **27 minutos**. Lo vimos al revisar el despliegue, no con Cotejo: **ninguno de los ocho controles del catálogo cubría los secretos**. Añadimos C-09, y en la ejecución de referencia encontró el secreto que sigue en el historial.

El error metodológico. En la primera ejecución, el control de cifrado informó MAL cuando el almacén estaba vacío. Lo correcto era SIN REVISAR. Es un defecto del criterio, no de la ejecución.



23 · También nos auditamos a nosotros · Sergio · ≈ 45 s

Sergio: Esta es la diapositiva más importante, porque habla de nuestros errores. Primero, el incidente: publicamos un secreto de firma en el repositorio durante 27 minutos. Lo vimos nosotros al revisar el despliegue, no Cotejo, porque ninguno de los ocho controles del catálogo cubría los secretos: el catálogo tenía un hueco. Lo cerramos con C-09, que en la ejecución de referencia encontró el secreto que sigue en el historial. Segundo, un error de método: el control de cifrado dijo MAL con el almacén vacío, cuando lo correcto era SIN REVISAR. Fue un error del criterio, no de la ejecución.

INDICACIÓN Decirla despacio.

SI PREGUNTAN ¿Qué aportó C-09? Separa lo que sigue expuesto, el historial, de lo que ya no abre nada: C-09c firma un token con el secreto hallado y comprueba que el sistema lo rechaza.

Trazabilidad de la evidencia

Cada papel de trabajo conserva cinco cosas:

1. el procedimiento ejecutado
2. la salida literal, sin editar
3. la marca de tiempo
4. la identidad bajo la que se ejecutó
5. una **huella SHA-256** del archivo

Sin las cinco, un resultado de auditoría es una afirmación.

Alcance de la huella. Permite comprobar que el papel no cambió después de escribirse. No permite verificar sin tenerlo.



24 · Trazabilidad de la evidencia · Sergio · ≈ 30 s

Sergio: Cada papel de trabajo conserva cinco cosas: el procedimiento ejecutado, la salida literal sin editar, la marca de tiempo, la identidad con que se ejecutó y una huella SHA-256 del archivo. Sin las cinco, un resultado de auditoría es solo una afirmación. Y precisamos lo que garantiza la huella: que el papel no cambió después de escribirse; no permite verificarlo sin tenerlo.

INDICACIÓN Ser exactos con la huella: exagerar lo que garantiza haría perder credibilidad en todo lo demás.

BLOQUE 7

Conclusiones y mejoras

- 25 Resultados generales
- 26 Acciones correctivas
- 27 Limitaciones declaradas
- 28 Cierre



Resultados generales

- Once controles evaluados, **ninguno sin ejecutar**
- Diez conformes, uno desviado
- Tres hallazgos: uno corregible, dos permanentes por el entorno
- Dos ejecuciones: diez controles **se repiten igual**; C-02 cambia por la única diferencia introducida a propósito
- 34 pruebas del propio programa, dentro de una suite de 234 en verde

Lo que el catálogo cubre, el programa lo verifica de forma repetible. Lo que no cubría lo reveló un incidente, y hoy lo cubre C-09.



25 · Resultados generales · Sergio · ≈ 40 s

Sergio: En resultados: once controles evaluados y ninguno sin ejecutar; diez conformes y uno desviado; tres hallazgos, uno corregible y dos permanentes por el entorno. En las dos ejecuciones, diez controles dieron lo mismo y C-02 cambió solo por lo que cambiamos a propósito: cargar una evidencia. El programa tiene además sus 34 pruebas. La conclusión de fondo: lo que el catálogo cubre, el programa lo verifica de forma repetible; lo que no cubría lo reveló un incidente, y hoy lo cubre C-09.

Acciones correctivas

Acción	Responsable	Prioridad	Tiempo
Partir el control de cifrado en dos	Oscar Rincón	Alta	4 horas
Validación en doble sentido de cumplimiento	Nicolás Torres	Alta	1 semana
Credenciales de solo lectura y cuenta separada	Nicolás Torres	Alta	1 semana · depende del entorno
Firma asimétrica y anclaje externo	Sergio Montoya	Media	3 semanas · depende del entorno
Retención inmutable del almacén	Sergio Montoya	Media	4 horas · depende del entorno
Validar el informe con auditores externos	Oscar Rincón	Media	2 semanas

Las dos primeras no dependen del entorno. Son las que podemos ejecutar ya.



26 · Acciones correctivas · Sergio · ≈ 35 s

Sergio: Estas son las acciones correctivas, con responsable, prioridad y tiempo. Las dos primeras no dependen del entorno y las podemos hacer ya: partir el control de cifrado en dos, en unas cuatro horas, y automatizar la validación en doble sentido de los controles de cumplimiento, en una semana. Las siguientes dependen de permisos que el laboratorio no da: credenciales de solo lectura, firma asimétrica y retención inmutable. La última es validar el informe con auditores externos.

SI PREGUNTAN El criterio de cierre de cada acción está en el apartado 15.2 del documento.

Limitaciones declaradas

Independencia. Auditamos lo que construimos. Hay rotación interna y el programa es determinista, pero esto no alcanza la independencia de una revisión externa.

Cobertura. Solo se verifican los controles del catálogo.

Valor probatorio. El ejecutor tiene permisos de escritura sobre lo que audita.



27 · Limitaciones declaradas · Sergio · ≈ 25 s

Sergio: Tres limitaciones, que están en el propio informe que genera el programa. Independencia: auditamos lo que construimos; tenemos rotación interna y un programa determinista, pero eso no equivale a una revisión externa. Cobertura: solo verificamos lo que está en el catálogo. Y valor probatorio: el ejecutor puede escribir sobre lo que audita. Nicolás cierra.

Cierre

Dos reglas sostuvieron el trabajo:

Declarar el criterio antes de ejecutar la prueba.

No clasificar como aprobado ni como reprobado lo que no se pudo comprobar.

github.com/Serann10255/Rastro



Cotejo

Bloque 7 · Conclusiones y mejoras

28 / 28

28 · Cierre · Nicolás · ≈ 20 s

Nicolás: Terminamos con las dos reglas que sostuvieron el trabajo: declarar el criterio antes de ejecutar la prueba, y no clasificar como aprobado ni como reprobado lo que no se pudo comprobar. Muchas gracias; quedamos atentos a sus preguntas.

INDICACIÓN Después de «gracias», callarse.